

NEXUM

Security Scan Report

Generated: 2026-05-17 18:18 UTC · Source: nodoc_power-platform.yml

30 / 100

Tier 0 — LOW RISK

3 findings total · 3 HIGH

Top Findings

[NEXUM-004] HIGH

/api/data/v9.0/RetrieveFeatureControlSettingsByNamespace
POST /api/data/v9.0/RetrieveFeatureControlSettingsByNamespace accepts no Idempotency-Key header. Network retries or agent replays can create duplicate resources or apply the same mutation more than once without any safeguard.

[NEXUM-004] HIGH

/api/data/v9.0/GetFeatureEnabledState
POST /api/data/v9.0/GetFeatureEnabledState accepts no Idempotency-Key header. Network retries or agent replays can create duplicate resources or apply the same mutation more than once without any safeguard.

[NEXUM-004] HIGH

/api/data/v9.0/\$batch
POST /api/data/v9.0/\$batch accepts no Idempotency-Key header. Network retries or agent replays can create duplicate resources or apply the same mutation more than once without any safeguard.

Full Findings — Grouped by Rule

NEXUM-004 — IdempotencyMissing (HIGH)

Path	Method	Severity
/api/data/v9.0/\$batch	POST	HIGH
/api/data/v9.0/GetFeatureEnabledState	POST	HIGH
/api/data/v9.0/RetrieveFeatureControlSettingsByNamespace	POST	HIGH

Guardrail: Add 'Idempotency-Key' as a required request header. The server must store the key and return the original response for duplicate requests received within a reasonable window.

Manual Review Required

- **model_compatibility_range:** Cannot be inferred from the spec. Depends on model capabilities, deployment context, and the desired trust level for this integration.
- **auto_detected_invariants.immutable_fields:** No readOnly properties found in component schemas. Manually list any fields that must never change after resource creation.
- **auto_detected_invariants.numeric_limits:** No numeric or length constraints found in component schemas. Specify min/max bounds for any safety-critical numeric fields.